

CHAPTER 1

*CIA Triad:

- Confidentiality: Chỉ người có thẩm quyền mới được truy cập thông tin. Ngăn lộ lọt dữ liệu.

- Integrity: Thông tin không bị chỉnh sửa hay phá hủy trái phép. Đảm bảo tính chính xác.

- Availability: Hệ thống & dữ liệu luôn truy cập được khi cần. Chống DoS.

CIA+

- Authenticity: Xác minh danh tính

- Accountability: Ghi lại audit log, truy vết.

- Non-repudiation: Không thể phủ nhận hành động đã làm

- Khái niệm:

- Attack: cố ý / vô ý gây hại thông tin / hệ thống.

- Threat: Những thứ có khả năng gây hại asset

- Threat Agent: Thành phần cụ thể mối đe dọa.

- Vulnerability: Lỗ hổng hệ thống có thể bị khai thác

- Risk: Xác suất mỗi đe dọa khai thác lỗ hổng, gây hại.

- Exploit: Hành động tận dụng lỗ hổng hệ thống.

- Exposure: t.hợp cụ thể bị lộ ra khả năng bị công

- Countermeasure: Cơ chế đối phó, giảm rủi ro

- Asset: Tài nguyên của tổ chức cần được bảo vệ

- Phân loại tấn công:

- Passive Attack

+Release of message contents: đọc nội dung truyền tin

+Traffic analysis: phân tích mẫu lưu lượng

->Khó phát hiện, dễ ngăn chặn

->Biện pháp: Prevention (mã hóa)

- Active Attack

+Masquerade: giả mạo danh tính

+Replay: ghi lại & phát lại gói tin

+Modification” sửa nội dung tin nhắn

+Denial of Service (DoS): làm tê liệt dịch vụ

->Dễ phát hiện, khó ngăn chặn

->Biện pháp: Detection & Recovery

- Attack Tree & Attack Surface

- Attack Tree: Sơ đồ khái niệm mô tả các cách một tài sản có thể bị tấn công. Root = mục tiêu; nhánh = phương thức tấn công.

- Attack Surface: Tổng hợp tất cả điểm có thể bị tấn công. Bề mặt càng nhỏ > càng dễ bảo vệ.

- Attack Vector: Phương pháp cụ thể: phishing, malware, mật khẩu yếu, mã hóa kém, phần mềm chưa vá.

- Các nguyên tắc thiết kế bảo mật

1. Minimise attack surface area – Giảm thiểu vector tấn công vào hệ thống

2. Establish secure defaults – Thiết lập cơ chế mặc định an toàn

3. The principle of Least Privilege – Nguyên tắc đặc quyền tối thiểu

4. The principle of Defence in depth – Nguyên tắc bảo mật theo chiều sâu, nhiều lớp

5. Fail Securely – Nguyên tắc xử lý thất bại một cách an toàn

6. Don’t trust services – Không tin tưởng tuyệt đối vào dịch vụ

7. Separation of duties – Tách biệt về nhiệm vụ

8. Avoid security by obscurity – Tránh bảo mật bằng việc che giấu

9. Keep Security simple – Giữ bảo mật một cách đơn giản

10. Fix security issues correctly – Và lỗ hổng bảo mật mới cách đúng đắn

- Chiến lược bảo mật tổng thể

- Specification/Policy: Xác định hệ thống bảo mật phải làm gì (chính sách)

- Implementation/Mechanism: Làm thế nào để thực hiện: Prevention → Detection → Response → Recovery

- Correctness/Assurance: Xác nhận hệ thống có thực sự hoạt động đúng không (đánh giá, kiểm tra)

CHAPTER 2

- Software security issues

Insecure interaction: Invalidated input, XSS, buffer overflow, injection flaws, improper error handling

Risky resource management: Buffer overflow, path traversal, download code không kiểm tra integrity

Leaky defenses: Missing authentication/authorization, hard-coded credentials, missing encryption

- Nguồn gốc lỗ hổng phần mềm

- Bugs trong ứng dụng: phần mềm không làm đúng những gì nó phải làm (ví dụ: cờ truy cập bị thay đổi qua input)

- Tính năng không phù hợp: phần mềm làm những thứ không được phép (ví dụ: hàm search hiển thị thông tin user khác)

- Nguyên nhân chính: độ phức tạp cao của tính năng (functionality > security) và developer thiếu ý thức bảo mật

- Secure software — 4 nguyên tắc vàng:

- Never trust user input

Không bao giờ tin tưởng dữ liệu đầu vào từ người dùng mà không validate

- Don’t reinvent the wheel

Tái sử dụng code đã kiểm chứng, không tự viết lại từ đầu (Intelligent code reuse)

- Don’t trust developers

Kiểm tra code, peer review — không tin tuyệt đối vào developer

- Use immutable objects

Dùng immutable thay mutable object để giảm rủi ro thay đổi trạng thái

- Các register quan trọng

EIP / RIP – Instruction Pointer: trỏ đến lệnh tiếp theo sẽ thực thi (32-bit / 64-bit)

EBP – Frame Pointer: trỏ đến vị trí cố định trong stack frame hiện tại

ESP – Stack Pointer: trỏ đến đỉnh stack, thay đổi liên tục khi push/pop

- Stack Frame — 4 vùng quan trọng (theo thứ tự từ cao > thấp)

- Arguments (tham số): ebp+8, ebp+12...

- Return Address (địa chỉ trả về): ebp+4 là MỤC TIÊU TẤN CÔNG

- Previous Frame Pointerebp — lưu ebp của frame trước

- Local Variables (biến cục bộ)ebp-4, ebp-8... — ĐÂY LÀ BUFFER

-> Stack phát triển từ địa chỉ cao > thấp. Dữ liệu copy vào buffer lại phát triển từ thấp > cao > tràn lên đè Return Address.

- Buffer Overflow — cơ chế tấn công:

Xảy ra khi dữ liệu ghi vào buffer vượt quá kích thước đã cấp phát, ghi đè lên vùng nhớ liền kề — đặc biệt là Return Address trên stack.

- Nguyên nhân phổ biến

+ Dùng hàm không giới hạn kích thước: strcpy(), gets(), strcat()

+ Không kiểm tra độ dài input trước khi copy

+ Developer không validate dữ liệu người dùng

- Hậu quả khi bị tấn công

+ Chương trình crash (Segmentation fault)

+ Hacker hijack execution — chạy mã độc tùy ý

+ Ghi đè Return Address → nhảy đến shellcode

+ Leo thang đặc quyền (privilege escalation)

- Countermeasures chống Buffer Overflow

- Safer functions: Dùng hàm có giới hạn kích thước Vd: strncpy() thay strcpy()

- StackGuard / Stack Canary: Đặt giá trị sentinel trước Return Address; kiểm tra trước khi return về: gcc -fstack-protector -> phát hiện ghi đè Stack

- ASLR: Address Space Layout Randomization — ngẫu nhiên hóa địa chỉ bộ nhớ mỗi lần chạy Vd: kernel.randomize_va_space=2

- Non-executable Stack (NX/DEP): Đánh dấu vùng stack không có quyền thực thi — shellcode không chạy được Vd: gcc -z noexecstack

- Static analyzer: Phân tích mã nguồn tự động phát hiện lỗi trước khi chạy Vd: Coverity, Flawfinder

- Safe language: Dùng ngôn ngữ có kiểm tra biên tự động Vd: Java, Python, Rust

- Security trong SDLC — tích hợp bảo mật từng giai đoạn

- Requirements: Abuse Cases, xác định Security Requirements, Risk Analysis

- Design: Risk Analysis, Attack Surface Analysis/Reduction, Threat Modeling

- Code: Static Analysis, Peer Code Review

- Testing: Penetration Testing, Attack Surface - Review, Application Fuzzing

- Release: Final Security Review

- Feedback: Operational Security — và lỗi sau triển khai

CHAPTER 3

- Khái niệm cơ bản:

- Trusted Computing Base

+ Tập hợp phần cứng/phần mềm được tin tưởng bảo vệ bí mật

+ 3 yêu cầu: Tamper-proof, Complete mediation, Correct

+ Kiểm soát truy cập qua: Authentication → Authorization

- Operating System

+ 3 lớp: Hardware → OS → Application/User

+ Chức năng: quản lý tài nguyên, bảo mật, xác thực, lập lịch

+ OS bị xâm phạm → toàn bộ hệ thống bị xâm phạm

- OS Security Environment

+ Services: xác thực, remote access, quản trị

+ Files: quyền đọc/ghi/thực thi

+ Memory: ngăn chặn phần mềm viết xấu

- File permissions – Unix/Linux

- Cấu trúc:

[file type] [owner: rwx] [group: rwx] [other: rwx]

- SETUID (Set User ID) — bit 4: SETUID được bật, process chạy với quyền của owner của file thay vì người thực thi.

- SETGID (Set Group ID) — bit 2:

Trên file: Process chạy với quyền của group sở hữu file thay vì group của người thực thi.

Trên directory — quan trọng hơn: Mọi file/thư mục tạo bên trong sẽ tự động kế thừa group của thư mục cha, thay vì group của người tạo.

- Sticky Bit – bit 1

Trong thư mục có sticky bit, user chỉ có thể xóa hoặc đổi tên file của chính mình, dù có quyền write trên thư mục đó.

- Quy ước:

7	rwX	đọc + ghi + thực thi
6	rw-	đọc + ghi
5	r-X	đọc + thực thi
4	r--	chỉ đọc
0	---	không có quyền nào

- Các phương thức xác thực (Authentication)

- Vật lý

Magnetic card, biometric

Kiểm soát vào cơ sở vật chất

- Kỹ thuật số

Digital certificate

Digital token (OTP mỗi lần)

Smart card (electronic circuit)

Kerberos (MIT, dùng ticket)

- Giao thức

LDAP – centralized directory

NTLM – challenge/response (Microsoft)

PKI – public/private key

RADIUS – centralized cho network

SSL – mã hóa kênh truyền

SRP – không lưu mật khẩu local =>Authentication (xác thực danh tính) → Authorization (cấp quyền).

- Lỗ hổng OS (Vulnerabilities)

- Windows:

+IIS, MS SQL Server

+Windows Authentication

+Internet Explorer, MDAC

+WSH, Outlook/Outlook Express

+P2P File Sharing, SNMP

- UNIX/Linux

+ BIND DNS, RPC

+ Apache Web Server

+ Tài khoản không có/mật khẩu yếu

+ Clear text services, Sendmail

+ SNMP, SSH, NIS/NFS, OpenSSL

- OS Hardening – các bước bảo mật hệ điều hành

- Bước cơ bản

+ Cài đặt vá và (patch) OS

+ Xóa services/ứng dụng không cần

+ Cấu hình users, groups, permissions

+ Cài antivirus, firewall, IDS

+ Kiểm tra bảo mật sau cấu hình

- Harden Windows

+ Tắt RPC, Telnet, UPnP, IIS, Guest

+ Dùng NTFS file system

+ Tắt Remote Desktop, auto-login

+ Tắt File & Print Sharing

+ Cấu hình SYN-ACK retransmission

- Harden Linux

+ Mã hóa truyền thông, dùng SSH

+ Tránh FTP, Telnet, Rlogin

+ Dùng SELinux, iptables, TCPWrappers

+ Tắt root login, khóa tài khoản thất bại

+ Logging, auditing, IDS

+ Tắt USB/firewire/thunderbolt

- Password policy

- Password aging: đặt thời hạn mật khẩu

- Password reuse: không dùng mật khẩu cũ

- Password history: lưu lịch sử tránh lặp

- Encryption: mã hóa mật khẩu lưu trữ

- Complexity: chữ hoa, số, ký tự đặc biệt

- Logon retries: giới hạn số lần đăng nhập sai

- Single sign-on: đăng nhập 1 lần, dùng nhiều hệ thống

- Dictionary attack: thử mọi từ trong từ điển → cần mật khẩu phức tạp

- Virtualization Security

- Lợi ích bảo mật VM

+ Abstraction và isolation

+ Không phức tạp sau tấn công

+ Patching an toàn hơn

+ Tiết kiệm chi phí thiết bị bảo mật

- Vấn đề bảo mật VM

+ VM Sprawl – quá nhiều VM khó quản lý

+ Hypervisor Intrusion / Modification

+ Mobility – VM di chuyển giữa host

+ DoS – từ chối dịch vụ

CHAPTER 4

- Khái niệm cơ bản

- Authentication: Ai được truy cập? — Xác minh danh tính (credentials)

- Authorization: Được làm gì? — Cấp quyền truy cập tài nguyên

- Accounting: Đã làm gì? — Ghi log, kiểm tra tuân thủ chính sách

- Authentication Goals — 3 mục tiêu

- Availability: Cung cấp tài nguyên khi thông tin xác thực đúng

- No false negative: Không cho truy cập khi thông tin xác thực SAI

- No false positive Không từ chối khi thông tin xác thực ĐÚNG

- Authentication Factors

- Something you KNOW: Password, PIN, câu hỏi bảo mật

- Something you HAVE: Smart card, token, OTP SMS

-Something you ARE: Vân tay, móng mắt, khuôn mặt

- Password, Tấn công & bảo vệ

1. Offline dictionary:

Lấy file password, so sánh hash với danh sách phổ biến

2. Specific account

Nhắm vào 1 tài khoản, đoán liên tục đến khi đúng

3 Popular password:

Dùng password phổ biến thứ trên nhiều tài khoản

4. Workstation hijacking

Chờ máy bỏ trống, truy cập trực tiếp

5. User mistakes

Khai thác sai lầm: viết password ra giấy

6. Multiple password use

Dùng chung 1 password cho nhiều dịch vụ

7. Electronic monitoring

Nghे lén password qua mạng (eavesdropping)

- Password Rules — Quy tắc bắt buộc

- Mã hóa một chiều (one-way hash)

- Tối thiểu 8 ký tự (tốt nhất 12+), gồm chữ hoa, thường, số, ký tự đặc biệt

- Đổi mỗi 30 ngày, cảnh báo trước

- Lưu lịch sử để không tái sử dụng trong 1 năm

- Không ghi ra giấy, không để gần máy

- Không dùng tên gia đình, thú cưng làm password

***Hashed Password — Cách hoạt động (UNIX Scheme)**

- Method 1 Lưu danh sách password → Nguy hiểm, admin biết password

- Method 2 Không lưu password, lưu kết quả hash (one-way function)

=> UNIX: Password + Salt → Slow Hash Function → Lưu (UserID, Salt, Hash)

- Salt giúp chống dictionary attack và rainbow table attack

***Admin & Login ID Rules**

- Giới hạn số tài khoản admin

- Admin password chỉ 1 người biết, lưu trong phong bì niêm phong

- Admin account không bao giờ bị lock out

- Đổi tên các account mặc định: Guest, Administrator, Admin

- Session timeout yêu cầu nhập lại password

***Biometric Authentication**

- **Vân tay:** chính xác Cao, bảo mật Cao, lỗi -phổ biến: Da khô, bẩn, tuổi tác

- **Mô hình mắt (iris):** chính xác Rất cao, bảo mật Rất cao, lỗi phổ biến Ánh sáng kém

- **Võng mạc (Retina):** chính xác Rất cao, bảo mật Cao, lỗi phổ biến Cần kính

- **Khuôn mặt:** chính xác Cao, bảo mậtTrung bình, lỗi phổ biến Ánh sáng, tuổi, kính

- **Chữ ký:** chính xác Cao, bảo mậtTrung bình, lỗi phổ biến Chữ ký thay đổi

- **Giọng nói:** chính xác Cao, bảo mật Trung bình, lỗi phổ biến Ổn, cảm lạnh

***3 chế độ hoạt động của Biometric System**

- **Enrollment-Đăng ký:** thu thập mẫu sinh trắc học, lưu vào DB

- **Verification-Xác minh:** so sánh với 1 mẫu → True/False (1:1)

- **Identification-Nhận dạng:** so sánh với N mẫu → Trả về danh tính (1:N)

***Token-Based Authentication:**

- **Memory Card:** Lưu mã bảo mật đơn giản (không thể xử lý)

Ví dụ: thẻ ATM (từ tính)

Dùng đọc lập hoặc kết hợp PIN

=> Nhược điểm: Cần reader đặc biệt, nếu mất + biết PIN → mất bảo mật

-**SmartCard:**Có CPU, bộ nhớ, cổng I/O riêng

+ Có thể có crypto co-processor

+ Giao tiếp: wired/wireless

+ Giao thức: Static / Dynamic password / Challenge-Response

- **Dynamic Passwords (OTP)**

+ TOTP Time-based OTP — mã dựa trên thời gian hiện tại

+ HOTP HMAC-based OTP — mã dựa trên hash của password trước

=> Kết hợp với password thường → Two-Factor Authentication (2FA)->Giải quyết vấn đề dùng chung password nhiều nơi

***MFA & Passwordless:**

- Single-FA: Password / PIN

- Two-FA (2FA): Password + OTP/Smartphone

- MFA: Password + Token + Biometric

MFA làm giảm false negative vì attacker khó đoán được cả 2 yếu tố

***Single Sign-On (SSO)**

- Dùng 1 bộ credential đăng nhập nhiều ứng dụng trong enterprise

- **Ưu điểm**

1 password thay tất nhiều password · ID nhất quán · Giảm admin · Truy cập nhanh

- **Nhược điểm**

Single point of failure → compromise toàn bộ · Phức tạp · Đắt

***PHAAT:**

Phone-As-A-Token — điện thoại là token

Các hãng lớn: Apple, Microsoft, Samsung, Amazon đang triển khai

***Threats & Security Issues:**

Client attack (Password):

Vd Brute-force, exhaustive search

Phòng thủ: Entropy lớn, giới hạn số lần thử

Client attack (Token):

Vd: Exhaustive search

Phòng thủ: Giới hạn thử, cần vật lý có token

Host attack (Password):

Vd: Đánh cắp plaintext, dictionary

Phòng thủ: Hashing, bảo vệ DB password

Host attack (Token):

Vd: Đánh cắp passcode

Phòng thủ: OTP 1 lần dùng

Eavesdropping (Password):

Vd: Shoulder surfing

Phòng thủ: MFA, đổi password ngay

Replay:

Vd: Thắt lại password/token đã nghe

Phòng thủ: Challenge-response protocol

Trojan horse:

Vd: Cài client giả mạo

Phòng thủ: Xác thực client trong security perimeter

DoS:

Vd: Khóa tài khoản bằng sai nhiều lần

Phòng thủ: MFA với token

***Remote Authentication — thêm mối đe dọa**

- phức tạp hơn vì:

+ Eavesdropper có thể bắt được password qua mạng

+ Adversary có thể replay lại authentication sequence

=> Giải pháp: Challenge-Response Protocol — server gửi challenge ngẫu nhiên, client trả response có hash(password + challenge)

***4 Assurance Levels**

- Level 1 Ít/Không tin tưởng vào danh tính được xác nhận

- Level 2 Một phần tin tưởng

- Level 3 Tin tưởng cao

- Level 4 Tin tưởng rất cao

CHAPTER 4.2

***Khái niệm cơ bản**

- **Access Control:** Tập hợp cơ chế cho phép quản lý hệ thống kiểm soát ai được làm gì trên tài nguyên nào. Gồm 2 phần chính: Authentication Authorization

- **3 thực thể quan trọng (AAA):**

Authentication: Xác thực danh tính

Authorization: Cấp quyền truy cập

Audit: Ghi log & kiểm tra hoạt động

- **Subject:** Thực thể chủ động (user, process)

- **Object:** Tài nguyên thụ động (file, printer)

- **Principal:** Thuộc tính của subject (UID, key)

- **Access Rights (quyền truy cập)**

Read · Write · Execute · Delete · Create · Search.

Lưu ý: Write bao gồm cả Read.

***Access Control Matrix (ACM)**

Rows = Subjects (users/groups)

Columns = Objects (resources)

Cell = quyền của subject trên object đó.

ACL = cột trong ACM (theo Object)

Capability List = hàng trong ACM (theo Subject)

- **ACL (Access Control List)**

Gắn với Object. Dễ kiểm tra "ai được vào file này".

Windows NT dùng ACL. Khó xem user có quyền gì tổng thể.

-**Capability List**

Gắn với Subject. Dễ kiểm tra "user này có quyền gì".

Khó kiểm tra "ai được vào object này".

***Các chính sách AC**

- **DAC Discretionary:** Chủ sở hữu file, Owner tự chia sẻ quyền. Không kiểm soát được luồng thông tin.

Ứng dụng: Linux chmod, Windows share

- **MAC Mandatory:** Hệ thống / Admin, Dùng nhãn (label). Kiểm soát luồng thông tin. Mục tiêu: Confidentiality.

Ứng dụng: Quân sự, tình báo (Top Secret...)

- **RBAC Role-Based:** Hệ thống (qua Role), Quyền gắn với vai trò, không phải cá nhân. Dễ quản lý.

Ứng dụng: Doanh nghiệp (Manager, Employee...)

- **ABAC Attribute-Based:** Policy + Thuộc tính, Điều kiện: attributes của user, object, môi trường. Linh hoạt nhất.

Ứng dụng: Cloud, hệ thống phức tạp

***Bell-LaPadula Model (BLP) — MAC cho MLS**

- Mục tiêu: đảm bảo Confidentiality trong hệ thống đa mức bảo mật

Nhãn (Label) = (Sensitivity Level, Compartments).

Mức độ: TS > S > C > U

L1 dominates L2 ⇔ l₁ ≥ l₂ AND Comp₁ ⊇ Comp₂

- **Simple Security (No Read Up)**

Subject S đọc Object O khi: L_m(S) ≥ L(O)

→ Không được đọc tài liệu có cấp cao hơn clearance.

- **Star Property (No Write Down)**

Subject S viết Object O khi: L_c(S) ≤ L(O)

→ Không được ghi xuống cấp thấp hơn (tránh rò rỉ).

Ví dụ so sánh label

L1 = (TS, {A,B,C}), L2 = (S, {A,B}), L3 = (S, {B,C,D})

L1 > L2 √ (TS > S và {A,B,C} ⊇ {A,B})

L1 và L3 không so sánh được ({A,B,C} không chứa {B,C,D})

***RBAC — mô hình phân cấp**

- **4 thực thể cơ bản (RBAC₀)**

Users → assigned to → **Roles** → assigned to → **Permissions**

Sessions: mapping user ⇔ tập role đang active

- **Các mức RBAC**

RBAC₀: Base (minimum)

RBAC₁: + Role hierarchies

RBAC₂: + Constraints

RBAC₃: Tất cả = Consolidated model

CHAPTER 6

***Khái niệm cơ bản**

- **Malware (NIST SP 800-83):**Chương trình được cài vào hệ thống, thường bí mật, nhằm xâm phạm C – I –

A của dữ liệu, ứng dụng hoặc hệ điều hành của nạn nhân, gây xuất hiện popup lạ

- **Phân loại theo cấu trúc**

+ Cần host: virus, logic bomb, backdoor

+ Độc lập: worm, bot (zombie)

Có thể tự nhân bản hoặc không

- **3 lớp kẻ xâm nhập**

+ Masquerader (outsider): giả mạo user hợp lệ

+ Misfeasor (insider): lạm dụng quyền

+ Clandestine: chiếm quyền supervisor

- **5 bước hacking**

1. Footprinting / Reconnaissance: thu thập thông tin, thăm dò

2. Scanning & Enumeration: quét và liệt kê

3. Gaining access: Chiếm quyền

4. Maintaining access: duy trì quyền

5. Covering track: xóa dấu vết

***Virus:**

- **3 thành phần virus**

+ Infection mechanism – cách lây lan

+ Trigger (logic bomb) – điều kiện kích hoạt

+ Payload – hành động thực thi

4 pha hoạt động

Dormant → Propagation → Triggering → Execution

Lan truyền, ẩn náu, kích hoạt, thực thi

- **Phân loại theo mục tiêu**

+ Boot sector: Lây qua MBR khi boot đĩa nhiễm

+ Parasitic (File): Bám vào .exe, chạy khi host chạy

+ Memory-resident: Nằm trong RAM, nhiễm các process đang chạy

+ Macro: Khai thác macro Word/Excel, đa nền tảng

- **Phân loại theo ẩn náu:**

+ Encrypted: Mã hoá bằng random key lưu cùng virus

+ Stealth: Ẩn khỏi antivirus scanner

+ Polymorphic: Biến đổi signature mỗi lần lây → vô hiệu hoá signature scan

+ Metamorphic: Viết lại toàn bộ code khi lây, thay cả hành vi, lẩn tránh bằng tự ghi đè

***Các loại malware khác**

- **Worm:** Tự lan qua mạng (email, remote exec); không cần user kích hoạt; tiêu thụ bandwidth. Ví dụ: Morris (1988), Code Red, SQL Slammer, Mydoom, Không cần host, Có nhân bản

- **Trojan:** Giả dạng phần mềm hợp lệ; có thể cài backdoor, keylog, dropper, phishing ngân hàng, Không cần host, Không nhân bản

- **Backdoor / Trapdoor:** Lối vào bí mật, bỏ qua xác thực; rất khó chặn ở OS, Có cần host, Không nhân bản

- **Logic Bomb:** Kích hoạt theo điều kiện (ngày giờ, file, user). Loại kích hoạt theo ngày = Time Bomb, Có cần host, Không nhân bản.

- **Rootkit:** Sửa đổi OS kernel/API; 4 loại: Persistent / Memory-based / User mode / Kernel mode; thường cài qua Trojan, Không cần host, Không nhân bản

- **Bot / Zombie:** Chiếm quyền máy khác; Botnet = tập hợp bot; dùng cho DDoS, spam, keylog. 50–80% spam toàn cầu từ zombie, Không cần host, Không nhân bản

- **Ransomware:** Mã hoá file / khoá hệ thống, đòi tiền chuộc. Dùng dual encryption: symmetric key + asymmetric public key, Không cần host, Không nhân bản

- **Adware / Spyware:** Hiển thị quảng cáo / thu thập thông tin người dùng, Không cần host, Không nhân bản

- **Keylogger:** Ghi lại keystroke → đánh cắp mật khẩu, thẻ tín dụng, Không cần host, Không nhân bản

***Biện pháp phòng chống**

- **Antivirus – 4 thế hệ**

Gen 1: Signature scanner

Gen 2: Heuristic scanner

Gen 3: Activity monitor (real-time)

Gen 4: Combination package

- **Generic Decryption (GD)**

Chạy file qua emulator CPU → cho virus tự giải mã → scan signature → trade-off: thời gian vs tỉ lệ phát hiện

- **Digital Immune System**

Virus-infected machine → Admin machine → Virus Analysis Machine (extract signature) → gửi prescription về toàn mạng

- **Behavior-Blocking**

Admin định nghĩa policy → sandbox code khả nghi → alert admin → quyết định cho chạy hay xoá

- **Worm countermeasures**

Signature-based filtering

Filter-based containment

Payload classification

Threshold scan detection

Rate limiting / halting

- **Ransomware prevention**

Backup 3-2-1 (3 bản, 2 định dạng, 1 offline)

Patch : vá

Control access

Đừng trả tiền chuộc

Security awareness

***Phân tích malware**

- **Static Analysis**

Không cần chạy code. Kiểm tra strings, header, hash, metadata. Giới hạn: bỏ sót runtime behavior ẩn.

- **Dynamic Analysis**

Chạy code trong sandbox. Quan sát hành vi thực tế (registry, network, process) mà không nguy hiểm hệ thống thật.

- **Hybrid Analysis**

Kết hợp cả Static + Dynamic. Đầy đủ nhất.

- **4 giai đoạn phân tích**

1. Static Properties Analysis

2. Interactive Behavior Analysis

3. Fully Automated Analysis

4. Manual Code Reversing: đảo ngược mã thủ công